



Dovetail

Dovetail Research Pty Ltd

Third-Party Risk Review — Customer Research & Intelligence Platform

⚠️ APPROVE WITH PROVISIONS

Assessor: Conveyor TPRM
Assessment Date: Mar 12, 2026
Version: v1

1 EXECUTIVE SUMMARY

Company Overview

Dovetail Research Pty Ltd, founded in 2016 and headquartered in Sydney, Australia, provides a cloud-based customer research and intelligence platform used by enterprises including Atlassian, Spotify, and JP Morgan Chase for storing, analyzing, and deriving insights from qualitative research data [SOC-01, p.13, Section III; WEB-01, dovetail.com].

Business Use Case

Conveyor will use Dovetail as a customer research platform for storing and analyzing interview recordings, transcripts, survey responses, customer feedback, and other qualitative research data, including audio/video files and PII from research participants.

RISK SNAPSHOT

INHERENT RISK

HIGH
(PRELIMINARY)



RESIDUAL RISK

MEDIUM

- Processes sensitive qualitative research data including audio/video recordings containing research participant PII
- AI-powered analysis features process customer research data on Dovetail's AWS infrastructure with external transcription subprocessors (AWS, AssemblyAI)
- Multi-region AWS deployment (us-east-1, eu-west-1, us-east-2, ap-southeast-2) with broad subprocessor chain
- SOC 2 Type II (unqualified, BARR Advisory, Jul 2024–Jun 2025) covers Security, Confidentiality, Availability, Privacy, and HIPAA — no exceptions noted
- DPA breach notification lacks a specific hourly/day SLA — uses 'without undue delay' language only

Dovetail presents a **High** inherent risk profile driven by the sensitivity of data it will process: audio/video recordings of research interviews, transcripts containing verbatim participant statements, and PII of research participants who are not Conveyor employees. The platform's AI features analyze this data on Dovetail's own AWS infrastructure, with transcription routed to AWS or AssemblyAI subprocessors [ARC-01, p.1]. The combination of rich media files, verbatim PII, and AI-driven processing creates a material blast radius if the platform is compromised.

Dovetail demonstrates a **mature** security posture for a company of its age and stage. The vendor holds a current SOC 2 Type II report (BARR Advisory, July 2024–June 2025) with an unqualified opinion across Security, Confidentiality, Availability, Privacy, and HIPAA criteria — no exceptions were noted [SOC-01, p.5]. An annual penetration test was conducted in September 2025 by Razilio, which identified 1 High, 1 Medium, and 7 Low findings — all of which the vendor reports as remediated [PEN-01, p.2]. Dovetail also holds ISO/IEC 42001:2023 certification for its AI management system [GOV-07, p.1] and references ISO 27001:2022 as a framework compliance requirement [SOC-01, p.12].

Residual risk is assessed as **Medium**. Key controls — encryption in transit (TLS 1.3) and at rest, MFA-protected administrative access, network segmentation, continuous monitoring, quarterly access reviews, and daily backups — are auditor-verified [SOC-01, p.26; p.55; p.58]. However, gaps remain: the DPA lacks a specific breach notification SLA (stating only 'without undue delay') [GOV-05, p.4], the DPA is non-negotiable [GOV-06, p.1], no ISO 27001 certificate was provided for review despite it being referenced as a compliance framework, and penetration test remediation is self-attested by the vendor rather than independently validated.

One finding rated High (absent MFA for password-based application login) was identified during the September 2025 penetration test. Dovetail states this has been remediated with OTP-based 2FA [PEN-01, p.6; Penetration Test Response Table]. No security breaches have been publicly disclosed [WEB-01, dovetail.com/help/security-information].

RISKS IDENTIFIED

1 High-severity penetration test finding (MFA gap — vendor-attested as remediated), 1 Medium-severity finding (unauthenticated SSRF — vendor-attested as remediated), 7 Low-severity findings (all vendor-attested as remediated). DPA breach notification SLA is imprecise. ISO 27001 certificate not provided. DPA is non-negotiable.

RECOMMENDATION

Approve with Provisions. Dovetail's security program is mature and well-documented, supported by an unqualified SOC 2 Type II and a comprehensive penetration test. Residual risk is Medium. The business accepts the risk of housing sensitive research participant PII and audio/video recordings in a third-party SaaS platform with AI processing capabilities. Approval is conditioned on executing the DPA, confirming SSO/MFA enforcement for all Conveyor users, and verifying penetration test remediation.

Key Items to Examine

- Confirm all 9 penetration test findings are fully remediated — vendor self-attests remediation but no independent retest report was provided [PEN-01, Response Table]
- Execute the Dovetail DPA prior to uploading any research participant data; note the DPA is non-negotiable and breach notification uses 'without undue delay' rather than a specific SLA [GOV-05, p.4; GOV-06, p.1]
- Enforce SSO with MFA for all Conveyor user accounts to mitigate residual authentication risk; verify the newly deployed OTP-based 2FA is enabled for any password-based accounts
- Request the current subprocessor list from trust.dovetail.com/subprocessors and validate against Conveyor's data residency and AI processing requirements [ARC-01, p.1]
- Request a copy of Dovetail's ISO 27001 certificate — referenced as a compliance framework in the SOC 2 report but not provided for this review [SOC-01, p.12]

Key Mitigations Before Approval

- Execute the Dovetail DPA before any research data is uploaded; document Conveyor's acceptance of the 'without undue delay' breach notification language in lieu of a specific-hour SLA
- Configure SSO (SAML/OIDC via Auth0) with MFA enforcement for all Conveyor user accounts to eliminate password-only authentication risk
- Restrict Conveyor workspace roles to least privilege — the penetration test found viewer accounts could write data (since remediated), so verify RBAC enforcement before granting broad access [PEN-01, p.15]

2 INHERENT RISK ASSESSMENT

Product: Dovetail is a cloud-based customer research and intelligence platform that enables teams to store, organize, and analyze qualitative research data. Core capabilities include: storage of interview recordings (audio/video), automated transcription (via AWS Transcribe or AssemblyAI), survey response aggregation, tagging and thematic analysis, and AI-powered insight generation (Dovetail 3.0) [SOC-01, p.13, Section III; ARC-01, p.1; PEN-01, p.4]. The platform supports integrations with Zoom, Google Drive, OneDrive, Slack,

Notion, Atlassian, Productboard, Microsoft Teams, and Zapier [SOC-01, p.13, Section III]. All infrastructure is hosted on AWS across four regions (us-east-1, eu-west-1, us-east-2, ap-southeast-2) with no on-premises components [SOC-01, p.14].

Integration architecture: Conveyor users will access Dovetail via web browser. User authentication is handled via Auth0 (supporting SSO via SAML/OIDC) [ARC-01, p.1]. Data flows outbound from Conveyor to Dovetail include: interview recordings (audio/video), transcripts, survey responses, customer feedback text, and research participant PII (names, contact information, demographics, verbatim quotes). Inbound data includes: AI-generated insights, tagged themes, transcriptions, and exported reports. Audio/video files are stored in AWS S3; text data is stored in AWS RDS [ARC-01, p.1]. Transcription is performed by AWS or AssemblyAI — video is sent to the transcription provider and transcriptions are returned to Dovetail [ARC-01, p.1]. All AI features run on Dovetail's own AWS infrastructure and are not sent outside, per vendor claim [ARC-01, p.1] (vendor-self-attested; not independently verified). The blast radius of a compromise is significant: an attacker would gain access to raw research recordings, participant PII, and potentially confidential product strategy insights derived from customer feedback. Dovetail uses subprocessors including AWS, AssemblyAI, and others listed at trust.dovetail.com/subprocessors [SOC-01, p.35; GOV-05, p.5]. Subprocessor changes are communicated at least 14 days in advance [SOC-01, p.29, PR-06].

DATA CLASSIFICATION & RISK TIER

SCENARIO	CLASSIFICATION	TIER
Research participant PII (names, email addresses, demographics, contact information)	Confidential	HIGH
Audio/video interview recordings containing participant voices, faces, and verbatim statements	Confidential	HIGH
Interview transcripts with verbatim participant quotes	Confidential	HIGH
Survey responses and customer feedback data	Confidential	HIGH
AI-generated research insights and thematic analysis	Internal	MEDIUM
Conveyor employee user credentials and access metadata	Confidential	HIGH

Inherent risk is *High*. Dovetail will process and store sensitive qualitative research data including audio/video recordings of research interviews, PII of external research participants, and verbatim transcripts — all classified as Confidential. The platform's AI features analyze this data to generate insights, adding a processing dimension beyond simple storage. Transcription involves external subprocessors (AWS or AssemblyAI) that receive raw audio/video [ARC-01, p.1]. The multi-region AWS deployment across four regions [SOC-01, p.14] and broad integration surface (Zoom, Slack, Google Drive, etc.) [SOC-01, p.13] expand the attack surface. This is a net new vendor for Conveyor, meaning no historical operational baseline exists. The combination of sensitive PII, rich media content, AI processing, and external subprocessor exposure places this engagement in the High inherent risk tier.

OVERALL INHERENT RISK: HIGH

3

RESIDUAL RISK ASSESSMENT

SECURITY POSTURE OVERVIEW

Dovetail Research Pty Ltd was founded in 2016 and is headquartered at Level 1, 276 Devonshire Street, Surry Hills, NSW 2010, Australia (ABN 84 615 270 025) [SOC-01, p.13; GOV-07, p.1]. The company operates a dedicated security function led by Nathan Miller (Head of Security and Compliance), with documented roles and responsibilities approved annually by management [SOC-01, p.63, IS-01]. The board of directors meets quarterly to discuss strategy, financials, and information security [SOC-01, p.65, IS-07]. The security program is supported by automated tooling (Vanta for compliance management, Datadog for observability, Amazon Inspector and GitHub Advanced Security for vulnerability scanning, PagerDuty for alerting) [SOC-01, p.16–17]. Dovetail holds a SOC 2 Type II (BARR Advisory, Jul 2024–Jun 2025, unqualified, covering Security, Confidentiality, Availability, Privacy, and HIPAA) [SOC-01, p.5], an ISO/IEC 42001:2023 certification for AI management (BARR Certifications, Jun 2025) [GOV-07, p.1], and references ISO 27001:2022 as a compliance framework [SOC-01, p.12]. Annual penetration testing is performed [SOC-01, p.12; PEN-01, p.2]. The security program also includes semiannual risk assessments [SOC-01, p.22], quarterly access reviews [SOC-01, p.55, AC-07], and monthly information system activity reviews [SOC-01, p.75, RC-08].

Dovetail is on a strong maturity trajectory for a 10-year-old SaaS company. The breadth of the SOC 2 scope (five TSC categories plus HIPAA), the ISO 42001 certification for AI governance, and the depth of the policy library (14+ security policies, all reviewed within the past 12 months) indicate an organization investing heavily in its security function. The next expected maturity milestone would be an ISO 27001 certification — currently referenced as a framework target but not yet provided as a certificate for review.

SOC 2 Type II

Unqualified

BARR Advisory, Jul 2024–Jun 2025, Security/Confidentiality/Availability/Privacy/HIPAA

ISO 42001:2023

Certified

BARR Certifications, Jun 2025–Jun 2028

Pen Test Findings

9 (1H / 1M / 7L)

Razilio, Sep 2025 — all self-attested as remediated

Reported Incidents

0

No disclosable incidents during audit period [SOC-01, p.30]

Uptime (90-day)

99.96%

Web application per status.dovetail.com

SOC 2 REPORT QUALITY — S2 GUILD RELIABILITY RUBRIC V1.0

To determine how much weight to place on the SOC 2 report when making the vendor trust decision, the report was evaluated against the SOC 2 Quality Guild Reliability Rubric v1.0 (s2guild.org) — an 11-signal framework assessing report reliability across three pillars: Structure, Substance, and Source.

Signal	Pillar	Rating	Key Finding
S1: Auditor Report Structure	Structure	PASS	The SOC 2 Type II report contains proper Scope, Management's Assertion, Independent Service

Signal	Pillar	Rating	Key Finding
			Auditor's Report, System Description, and Tests of Controls sections per AICPA standards. The auditor's opinion clearly states the examination basis, TSC criteria applied, and period covered [SOC-01, p.1–5].
S2: Management's Assertion Completeness	Structure	PASS	Management's assertion is present and includes formal statements about system accuracy, control effectiveness, and the basis for the assertion across all five TSC categories plus HIPAA [SOC-01, p.3–4].
S3: Inconsistent Language Across Sections	Structure	PASS	No material inconsistencies detected between the system description, management assertion, and auditor's opinion. Service commitments described in Section III align with the controls tested in Section IV [SOC-01, p.11–12; p.53–77].
S4: System Description Specificity	Substance	PASS	The system description names specific technologies (AWS, Kubernetes, Okta, Auth0, Datadog, Sentry, PagerDuty, GitHub, 1Password, Buildkite, Vanta), identifies four AWS regions, describes the VPC architecture, lists supporting tools with their functions, and names personnel roles [SOC-01, p.13–17]. This is a substantive description, not boilerplate.
S5: Control-to-Criteria Mapping Logic	Substance	PASS	Controls are mapped to specific TSC criteria in Section IV with a clear mapping table. The mapping is logical — e.g., AC controls map to CC6.x (Logical and Physical Access), CR controls map to CC6.1/CC6.7 (Encryption), BC controls map to A1.2 (Availability recovery) [SOC-01, p.37–52].
S6: Vague or Conflicting Control Descriptions	Substance	PASS	Control descriptions specify what, how, who, and when. For example, AC-05 specifies '10-character minimum and complexity' for passwords, AC-07 specifies 'quarterly' access reviews, AC-11 specifies '5 minutes' for inactivity lockout, and BC-03 specifies 'at least daily' backups using 'AWS

Signal	Pillar	Rating	Key Finding
			RDS' [SOC-01, p.55–58]. Controls are specific and actionable.
S7: Test Procedure Detail and Specificity	Substance	PASS	Test procedures describe the specific evidence examined (e.g., 'Inspected the population of detected or reported unauthorized disclosures' for PR-07, 'Inspected the vulnerability management policy' for TV-01). Test results include explicit 'no exceptions noted' language for passing controls and identify controls that 'did not operate' during the period with explanation [SOC-01, p.5; p.53–77].
S8: CPA Firm Registration and Peer Review	Source	PASS	BARR Advisory, P.A. is a well-known SOC 2 audit firm based in Fairway, Kansas, specializing in cloud security attestation. BARR is a recognized AICPA SOC practice and holds appropriate peer review status [SOC-01, p.1].
S9: CPA-to-SOC Reports Ratio	Source	ADEQUATE	BARR Advisory is a high-volume SOC audit firm. While exact CPA-to-report ratios are not publicly disclosed, BARR's reputation and specialization in SOC engagements suggest adequate staffing. No 'signature mill' indicators observed — the report contains substantive test descriptions and specific technical detail [SOC-01, p.53–77].
S10: Leadership Experience	Source	ADEQUATE	The engagement partner is identified in the report. BARR Advisory's leadership team is publicly documented as holding CPA credentials and SOC audit experience. BARR also issued the ISO 42001 certification through its BARR Certifications LLC subsidiary , indicating depth of relationship with the vendor.
S11: GRC Tool Usage	Source	ADEQUATE	Dovetail uses Vanta as its compliance management platform [SOC-01, p.16]. Vanta is a well-known GRC automation tool. Its use does not indicate an 'instant compliance' concern when paired with a substantive audit by a reputable firm. The level of test procedure detail in the report suggests genuine auditor

Signal	Pillar	Rating	Key Finding
			examination rather than automated pass-through.

The SOC 2 Type II report is assessed as ***Strong***. BARR Advisory is a reputable, specialized SOC audit firm. The report demonstrates substantive system description specificity, detailed control descriptions with measurable parameters, clear test procedures with explicit results, and proper structural compliance with AICPA standards. No exceptions were noted across all tested controls. Two privacy controls (PR-07, PR-08) did not operate during the period due to the absence of unauthorized disclosure incidents — this is appropriate and properly disclosed [SOC-01, p.5]. The report carries full evidentiary weight for this assessment.

KEY CONTROLS ASSESSMENT

KEY CONTROLS		
CONTROL	EVIDENCE	STATUS
Encryption in Transit	TLS 1.3 for data in transit; SSH for remote administration. Auditor-verified with no exceptions [SOC-01, p.60, CR-01]. Weak cipher suites on authentication API were identified in pen test and vendor-attests remediation [PEN-01, p.25].	✓
Encryption at Rest	Strong cryptography standards enforced per Cryptography Policy. Auditor-verified with no exceptions [SOC-01, p.60, CR-02]. AES-256 encryption claimed on trust center [WEB-01, dovetail.com/help/security-information] (vendor-self-attested for specific algorithm).	✓
Administrative Access Controls	AWS console access via Okta SSO with MFA; temporary credentials expire in <8 hours; VPN required for remote admin; root account usage logged with alerting [SOC-01, p.13; p.23; p.53, AC-01; p.53, AC-02; p.56, AC-10]. Auditor-verified.	✓
Quarterly Access Reviews	User access reviews performed quarterly for employees and contractors; issues resolved [SOC-01, p.55, AC-07]. Auditor-verified.	✓
Terminated User Access Removal	Access removed within one business day; offboarding checklists used [SOC-01, p.55, AC-06]. Auditor-verified.	✓
Network Segmentation	Segmented VPCs with ACLs; security groups with default-deny rules; IDS deployed at strategic points [SOC-01, p.26; p.75, SC-01]. Auditor-verified.	✓

KEY CONTROLS		
CONTROL	EVIDENCE	STATUS
WAF Protection	AWS WAF deployed to inspect HTTP(S) traffic and block common web application attacks [SOC-01, p.76, SC-02]. Auditor-verified.	✓
Vulnerability Scanning	Automated scanning via Amazon Inspector, GitHub Advanced Security, Vanta, AWS SecurityHub [SOC-01, p.16–17; p.28]. Auditor-verified.	✓
Annual Penetration Testing	2025 test by Razilio (Sep 1–11, 2025); 9 findings (1H, 1M, 7L); all self-attested as remediated [PEN-01, p.2; Response Table]. Commitment to annual testing auditor-verified [SOC-01, p.12].	✓
Incident Response Plan	Documented Security Incident Response Plan with severity classification (Low/Medium/High/Critical), escalation procedures, and CTO notification for critical incidents [SOC-01, p.25; p.67, OM-01; p.68, OM-02]. Auditor-verified.	✓
Business Continuity / Disaster Recovery	Documented BC/DR plan; annual DR testing; multi-AZ architecture; daily backups via AWS RDS [SOC-01, p.58, BC-02; BC-03; p.12]. Auditor-verified.	✓
Background Checks	Background or verification checks conducted for all new hires [SOC-01, p.12; p.62, HR-03]. Auditor-verified.	✓
Security Awareness Training	Security, privacy, and HIPAA training within 30 days of hire and annually [SOC-01, p.64, IS-02]. Auditor-verified.	✓
Secure SDLC	Separate dev/test environments without customer data; security analysis during change control; static analysis via CodeQL; developers cannot migrate own code to production [SOC-01, p.59, CM-02; CM-03; p.60, CM-05; p.27]. Auditor-verified.	✓
Data Deletion	Customer-initiated deletion from production; 30-day recovery window; permanent deletion from backups within 14 days of permanent deletion from live systems [SOC-01, p.68, OM-04; GOV-05, p.7]. SOC 2 confirms customer-initiated deletion;	✓

KEY CONTROLS

CONTROL	EVIDENCE	STATUS
	DPA specifies retention timelines (vendor-self-attested).	
Subprocessor Management	Third-party management policy; subprocessor list publicly maintained; 14-day advance notification of changes; confidentiality agreements with all vendors [SOC-01, p.29, PR-06; p.74, RC-04; p.35]. Auditor-verified.	✓

⚠️ RESIDUAL GAPS

- DPA breach notification SLA uses 'without undue delay' language rather than a specific timeframe (e.g., 72 hours). The DPA is non-negotiable per vendor policy [GOV-05, p.4; GOV-06, p.1]. Conveyor should document acceptance of this language.
- All 9 penetration test findings are self-attested as remediated by Dovetail [PEN-01, Response Table]. No independent retest report was provided to confirm remediation. The High-severity MFA finding and Medium-severity unauthenticated SSRF finding are of particular concern.
- ISO 27001 certificate was not provided for review despite ISO 27001:2022 being referenced as a system compliance requirement [SOC-01, p.12]. Web research indicates ISO 27001 certification is claimed [WEB-01, trust.dovetail.com], but no certificate was in the evidence package.
- AI processing details are limited to vendor-self-attested claims that 'all AI features run on our own AWS infrastructure and are not sent outside' [ARC-01, p.1]. This claim is not auditor-verified. Transcription subprocessors (AWS, AssemblyAI) do receive audio/video data [ARC-01, p.1].
- No public bug bounty program on HackerOne or Bugcrowd was identified. Dovetail maintains an internal Responsible Disclosure Policy [POL-11] but the external reporting mechanism is limited to an email address [WEB-01, dovetail.com/help/security-policies].
- The current subprocessor list was not included in the evidence package. The DPA references trust.dovetail.com/subprocessors [GOV-05, p.5], but the actual list requires direct verification by Conveyor.

VENDOR REQUIREMENTS COMPLIANCE

No customer-specific minimum vendor requirements were provided. The following evaluation uses the default requirements checklist defined in the assessment methodology.

REQUIREMENT	STATUS	NOTES
SOC 2 Type II (current, unqualified)	✓	SOC 2 Type II issued August 15, 2025, covering July 1, 2024 – June 30, 2025. Unqualified opinion. BARR Advisory. Covers Security, Confidentiality, Availability, Privacy, and HIPAA [SOC-01, p.1-5].

REQUIREMENT	STATUS	NOTES
Annual penetration testing	✓	2025 pen test by Razilio, September 1–11, 2025. Annual commitment auditor-verified [SOC-01, p.12; PEN-01, p.2].
Encryption at rest and in transit	✓	TLS 1.3 in transit, strong cryptography at rest — auditor-verified [SOC-01, p.60, CR-01; CR-02]. AES-256 at rest per trust center (vendor-self-attested) [WEB-01, dovetail.com/help/security-information].
Incident response plan	✓	Security Incident Response Plan v1.9 documented [GOV-03]. Severity classification and escalation procedures auditor-verified [SOC-01, p.25; p.67, OM-01; p.68, OM-02].
Business continuity / disaster recovery plan	✓	BC/DR plan v1.4 documented [GOV-01]. Annual DR testing commitment and multi-AZ architecture auditor-verified [SOC-01, p.12; p.58, BC-01; BC-02].
Data Processing Agreement available	✓	DPA available (last updated August 8, 2024). Covers GDPR, UK GDPR, CCPA, and other US privacy laws. Includes EU SCCs and UK IDTA [GOV-05; GOV-06]. Note: DPA is non-negotiable [GOV-06, p.1].
Breach notification SLA defined	⚠	DPA states notification 'without undue delay' after becoming aware of a breach [GOV-05, p.4]. No specific hourly or daily SLA defined. For US Privacy Law data, opt-out requests forwarded within 5 business days [GOV-05, p.9].
Data deletion policy defined	✓	Customer-initiated deletion from production; 30-day recovery window; permanent deletion from backups within 14 days [GOV-05, p.7; SOC-01, p.68, OM-04]. 30 days post-termination to request return/deletion [GOV-05, p.7].
Background checks on employees	✓	Background or verification checks for all new hires — auditor-verified [SOC-01, p.12; p.62, HR-03].
Security awareness training	✓	Security, privacy, and HIPAA training within 30 days of hire and annually thereafter — auditor-verified [SOC-01, p.64, IS-02].

Dovetail passes 9 of 10 default minimum vendor requirements. The one partial result is the breach notification SLA — the DPA uses 'without undue delay' rather than a specific timeframe. This is a common formulation that

aligns with GDPR language but does not provide the precision (e.g., 72 hours) that some customers require. Given the DPA is non-negotiable, Conveyor should document acceptance of this language as part of the vendor approval.

OVERALL RESIDUAL RISK: MEDIUM

The inherent risk of this engagement is High, driven by the sensitivity of research participant PII, audio/video recordings, and AI processing of qualitative data. Dovetail's security controls substantially reduce this risk. The SOC 2 Type II report (BARR Advisory, unqualified, Jul 2024–Jun 2025) covers all five TSC categories plus HIPAA with no exceptions across tested controls [SOC-01, p.5]. Key risk-reducing controls — encryption (TLS 1.3 in transit, strong cryptography at rest), MFA-protected administrative access, network segmentation, quarterly access reviews, secure SDLC practices, continuous vulnerability scanning, daily backups, and annual DR testing — are all auditor-verified [SOC-01, p.53–77]. The 2025 penetration test by Razilio identified 9 findings (1 High, 1 Medium, 7 Low), all of which the vendor self-attests as remediated [PEN-01, p.2; Response Table]. No security breaches or disclosable incidents occurred during the audit period [SOC-01, p.30]. Residual risk remains Medium rather than Low due to: (1) the absence of independent verification that penetration test findings are fully remediated, (2) the imprecise breach notification SLA in the non-negotiable DPA, (3) the missing ISO 27001 certificate, and (4) the vendor-self-attested nature of AI processing boundary claims. These gaps are manageable through the buyer mitigations identified but prevent a Low residual risk designation.

4

ASSESSMENT DETAILS

The following assessment evaluates Dovetail against the SOC 2 Trust Service Criteria (CC1–CC9, Availability, Confidentiality, Privacy) supplemented by HIPAA criteria included in the SOC 2 scope, penetration test findings, and policy review. No customer-specific evaluation framework was provided; the default SOC 2 TSC framework is applied.

SOC 2 TYPE II — TRUST SERVICE CRITERIA

Unqualified Opinion

Criteria	Rating	Key Findings
CC1 — Control Environment	Satisfactory	Board of directors meets quarterly to discuss strategy, financials, and information security; composed of independent members [SOC-01, p.65, IS-07]. Executive management meets at least annually to review policies and set security roadmap [SOC-01, p.21]. Organizational chart maintained in BambooHR [SOC-01, p.62, HR-04]. Information security function with independent oversight documented and approved annually [SOC-01, p.63, IS-01]. Annual performance evaluations conducted [SOC-01, p.67, IS-09]. Comprehensive policy library approved annually and published via Vanta [SOC-01, p.64, IS-03]. No exceptions noted.
CC2 — Communication and Information	Satisfactory	Security policies including sanctions are approved annually and published on Vanta accessible to all personnel [SOC-01, p.64, IS-03]. Personnel required to read and acknowledge Information Security Policy within

Criteria	Rating	Key Findings
		30 days of start and annually [SOC-01, p.61, HR-02]. Types of data collected publicly communicated via Trust Center and reviewed annually [SOC-01, p.69, PR-01]. Incident management procedures documented and made available to internal and external users [SOC-01, p.68, OM-02]. No exceptions noted.
CC3 — Risk Assessment	Satisfactory	Formal risk assessment performed at least annually with identified risks documented in a risk register; mitigation strategies communicated to process owners [SOC-01, p.72, RC-01]. Semiannual risk assessment also conducted by the security team [SOC-01, p.22]. Continuous monitoring of KPIs with automated alerting [SOC-01, p.73, RC-03]. Cyber liability insurance maintained [SOC-01, p.74, RC-05]. Process to monitor new privacy laws and regulations [SOC-01, p.72, PR-09]. No exceptions noted.
CC4 — Monitoring Activities	Satisfactory	Monitoring and alarming configured to identify and notify management when thresholds crossed on key security and operational metrics [SOC-01, p.67, OM-01]. Security event reporting includes failed object access, daily IDS attacks, critical IDS alerts, failed logins, and network configuration changes [SOC-01, p.26]. Monthly information system activity reviews conducted [SOC-01, p.75, RC-08]. File integrity monitoring and alerting implemented [SOC-01, p.74, RC-07]. Tools include Datadog, Sentry, PagerDuty [SOC-01, p.17]. No exceptions noted.
CC5 — Control Activities	Satisfactory	Segregation of duties enforced — developers cannot migrate own code to production [SOC-01, p.27]. Branch protection settings enforced in production repositories [SOC-01, p.56, AC-09]. Policy and procedure documentation published for all relevant teams [SOC-01, p.21–22]. Each policy has an individual owner with accountability [SOC-01, p.22]. No exceptions noted.
CC6 — Logical and Physical Access Controls	Satisfactory	AWS console access via Okta SSO with MFA; temporary credentials expire in <8 hours [SOC-01, p.13; p.56, AC-10]. VPN required for remote admin access [SOC-01, p.13; p.23]. Root account usage logged with alerting [SOC-01, p.53, AC-02]. Admin access restricted to authorized personnel [SOC-01, p.54, AC-03]. Password minimums enforced (10-char with complexity) [SOC-01, p.55, AC-05]. Quarterly access reviews [SOC-01, p.55, AC-07]. Terminated user access removed within one business day [SOC-01, p.55, AC-06]. Workstation auto-lockout at 5 minutes [SOC-01, p.57, AC-11]. Endpoint encryption and antivirus [SOC-01, p.77, TV-03]. Physical access delegated to AWS subservice organization [SOC-01, p.41–42]. No exceptions noted.
CC7 — System Operations	Satisfactory	IDS deployed at strategic network points [SOC-01, p.14]. AWS WAF inspects HTTP(S) traffic [SOC-01, p.76,

Criteria	Rating	Key Findings
		SC-02]. Security groups with default-deny rules [SOC-01, p.75, SC-01]. Automated vulnerability scanning via Amazon Inspector, GitHub Advanced Security, AWS SecurityHub [SOC-01, p.16–17]. Annual third-party penetration testing [SOC-01, p.76, TV-02]. Vulnerability management program with timelines for remediation [SOC-01, p.12]. Incidents classified by severity with defined escalation; no disclosable incidents during audit period [SOC-01, p.25; p.30]. No exceptions noted.
CC8 — Change Management	Satisfactory	Changes developed and tested in separate environment without customer data [SOC-01, p.59, CM-02; CM-03]. Automated software updates for security patches [SOC-01, p.59, CM-04]. Security analysis during change control with vulnerabilities tracked to resolution [SOC-01, p.60, CM-05]. Static analysis via CodeQL [SOC-01, p.27]. Production deployment access restricted [SOC-01, p.56, AC-09]. No exceptions noted.
CC9 — Risk Mitigation	Satisfactory	Third-party management policy maintained [SOC-01, p.35]. Subservice organizations reviewed via SOC report review, regular meetings, and NDAs [SOC-01, p.35]. Confidentiality agreements with all vendors accessing customer data [SOC-01, p.74, RC-04]. BAAs in place with business associates storing ePHI [SOC-01, p.74, RC-06]. Anti-bribery and anti-corruption policy maintained [SOC-01, p.22]. No exceptions noted.
A1 — Availability	Satisfactory	Multi-AZ architecture across four AWS regions with failover capabilities [SOC-01, p.13; p.58, BC-02]. Daily backups via AWS RDS [SOC-01, p.58, BC-03]. BC/DR plan documented and tested annually [SOC-01, p.12; p.58, BC-01]. Status page maintained for customer visibility [SOC-01, p.12]. 99.96% uptime reported on status page . No exceptions noted.
C1 — Confidentiality	Satisfactory	Data classified into four sensitivity levels (Public, Restricted, Company Confidential, Customer Confidential) [SOC-01, p.18–19, IS-06]. Confidentiality agreements with vendors [SOC-01, p.74, RC-04]. File integrity monitoring and alerting [SOC-01, p.74, RC-07]. Monthly information system activity reviews [SOC-01, p.75, RC-08]. Customer data automatically deleted upon customer initiation [SOC-01, p.68, OM-04]. Network segmented by classification level [SOC-01, p.26]. Encryption in transit (TLS 1.3) and at rest [SOC-01, p.60, CR-01; CR-02]. No exceptions noted.
P1 — Privacy	Satisfactory	Types of data collected publicly communicated via Trust Center, reviewed annually [SOC-01, p.69, PR-01]. DPA available for customers [SOC-01, p.69, PR-03]. Subprocessor changes communicated 14 days in advance [SOC-01, p.70, PR-06]. Breach notification procedures documented; PR-07 (unauthorized disclosure

Criteria	Rating	Key Findings
		record) and PR-08 (breach notification) did not operate during the period because no incidents occurred — properly disclosed [SOC-01, p.5; p.70–71]. Process to monitor new privacy laws [SOC-01, p.72, PR-09]. No exceptions noted.
HIPAA — Security Rule	Satisfactory	HIPAA Security Officer documented in HIPAA Compliance Policy, approved annually [SOC-01, p.66, IS-08]. HIPAA-related training provided within 30 days of hire and annually [SOC-01, p.64, IS-02]. BAAs executed with business associates storing ePHI [SOC-01, p.74, RC-06]. Physical access controls delegated to AWS subservice organization with complementary controls documented [SOC-01, p.49–50]. No exceptions noted.

Audit period: July 1, 2024 – June 30, 2025. Audit firm: BARR Advisory, P.A. (Fairway, KS). TSC scope: Security, Confidentiality, Availability, Privacy, and HIPAA Security Rule. Two controls (PR-07, PR-08) did not operate during the period due to absence of unauthorized disclosure events — this is appropriately disclosed and does not constitute an exception [SOC-01, p.5]. No exceptions were noted across all other tested controls.

PENETRATION TEST SUMMARY

Razilio (Sydney, Australia) — September 1–11, 2025

Web application and API penetration test targeting the Dovetail staging environment (dovetailstg.com). Four account roles tested: viewer, contributor, manager, and admin. Focus areas: data exfiltration and privilege escalation. Methodology aligned to OWASP Top Ten 2023 and OWASP API Top Ten 2021 across seven test categories: authentication, authorization, session management, data validation, data protection, configuration management, and error handling [PEN-01, p.2–4; p.47].

Severity	Finding	Status
High	MFA not implemented for password-based login to the Dovetail application. No function within the app to enable MFA (CVSS v4.0: 7.4) [PEN-01, p.6].	VENDOR-ATTESTED AS REMEDIATED — 2FA VIA OTP IMPLEMENTED [PEN-01, RESPONSE TABLE]

Severity	Finding	Status
Medium	Unauthenticated Server-Side Request Forgery (SSRF) allowing backend EC2 server to call arbitrary URLs (CVSS v4.0: 6.9) [PEN-01, p.7–9].	VENDOR-ATTESTED AS REMEDIATED — AFFECTED ENDPOINT REMOVED AND REPLACED [PEN-01, RESPONSE TABLE]
Low	No CSV filtering on uploads/downloads — CSV injection payloads could be stored and exported (CVSS v4.0: 2.0) [PEN-01, p.10–12].	VENDOR-ATTESTED AS REMEDIATED [PEN-01, RESPONSE TABLE]
Low	Insufficient file upload filtering — file type validation based on extension only, allowing arbitrary file uploads (CVSS v4.0: 2.0) [PEN-01, p.13–14].	VENDOR-ATTESTED AS REMEDIATED [PEN-01, RESPONSE TABLE]
Low	Viewer accounts able to write data (upload/download files, create contacts) despite read-only intent (CVSS v4.0: 2.1) [PEN-01, p.15–19].	VENDOR-ATTESTED AS REMEDIATED [PEN-01, RESPONSE TABLE]
Low	Bearer JWT token transmitted in URL during WebSocket session initiation, exposing token to logs/history/proxies (CVSS v4.0: 2.1) [PEN-01, p.21–22].	VENDOR-ATTESTED AS REMEDIATED [PEN-01, RESPONSE TABLE]
Low	CSP headers not fully configured on Dovetail authentication API, increasing XSS/clickjacking susceptibility (CVSS v4.0: 2.3) [PEN-01, p.23–24].	VENDOR-ATTESTED AS REMEDIATED [PEN-01, RESPONSE TABLE]

Severity	Finding	Status
Low	Weak TLS cipher suites (SHA, CBC, RSA) enabled on authentication API alongside strong cipher suites (CVSS v4.0: 2.0) [PEN-01, p.25–27].	VENDOR-ATTESTED AS REMEDIATED [PEN-01, RESPONSE TABLE]
Low	URL parameter manipulation in S3 download links enabling Content-Disposition override to 'inline', facilitating XSS from uploaded HTML (CVSS v4.0: 2.0) [PEN-01, p.28–30].	VENDOR-ATTESTED AS REMEDIATED [PEN-01, RESPONSE TABLE]

The 2025 penetration test by Razilio identified 9 findings across a reasonable scope (web application, API, four user roles, OWASP-aligned methodology). No Critical findings were identified. The High-severity finding (absent MFA for password-based login) is notable because it indicates that at the time of testing, password-authenticated users had no MFA option — a significant gap for a platform handling sensitive research data. The Medium-severity SSRF finding (unauthenticated, allowing the server to call arbitrary URLs) carried material risk for server-side exploitation. Dovetail reports all 9 findings as remediated in the appended response table [PEN-01, Response Table], including deploying OTP-based 2FA and removing the affected SSRF endpoint. However, no independent retest report was provided to confirm these remediations. The OWASP Top 10 and API Top 10 coverage was thorough, with clean results in categories A04, A06, A07, A08, A09, API1, API4, API6, and API8–10 [PEN-01, p.32–33].

POLICY REVIEW

Dovetail provided 14+ security policy documents, all reviewed within the past 12 months by Nathan Miller (Head of Security and Compliance) [POL-01 through POL-14; GOV-01 through GOV-04]. Key policies include: Access Control (v1.4), Cryptography (v1.6), Data Management (v1.2), HIPAA Compliance (v1.3), Information Security (v1.8), Risk Management (v1.5), Secure Development (v1.4), Security Incident Response Plan (v1.9), Business Continuity and Disaster Recovery Plan (v1.4), Third-Party Management (v1.2), and Security Hardening Guidelines (v1.5). All policy areas are also covered and auditor-verified within the SOC 2 Type II report [SOC-01, p.7; p.21–29], so the policy documents serve as supplementary evidence confirming the vendor's stated intent. The policy library is comprehensive and well-maintained. No material policy gaps were identified relative to the SOC 2 scope.

5

ASSETS REVIEWED

 VENDOR DOCUMENTS

Document	Source
SOC 2 Type II Report – Security, Confidentiality, Availability, Privacy, and HIPAA Security Rule (BARR Advisory)	August 15, 2025
SOC 3 Report – Security, Confidentiality, Availability, and Privacy (BARR Advisory)	August 15, 2025
Dovetail Web and API Penetration Testing Report v1.0 (Razilio)	September 12, 2025
ISO/IEC 42001:2023 Certificate of Registration (BARR Certifications LLC)	June 6, 2025
CSA CAIQ v4.0.2 Self-Assessment	2025
Data Processing Agreement (Full)	August 8, 2024
Data Processing Agreement – Web/ Landing Page Summary	Undated
Certificate of Insurance – IT and Cyber Insurance (Marsh Pty Ltd)	October 9, 2025
System Architecture / Data Flow Diagram	Downloaded March 9, 2026
Access Control Policy (v1.4)	January 10, 2025
Anti-bribery and Anti-corruption Policy (v1.2)	January 16, 2025
Asset Management Policy (v1.5)	March 26, 2025
Business Continuity and Disaster Recovery Plan Information Security Policy (Third-Party)	February 25, 2025

 BUYER REFERENCE DOCUMENTS

Document	Reference
Vendor Risk Review – Arcade Software, Inc. (reference document for assessment methodology)	December 31, 2025

 VENDOR RESOURCES

Resource	URL
Dovetail Trust Center	https://trust.dovetail.com
Dovetail Status Page	https://status.dovetail.com
Dovetail Security Information	https://docs.dovetail.com/help/security-information
Dovetail Subprocessors List	https://trust.dovetail.com/subprocessors
Dovetail Privacy Policy	https://dovetail.com/help/privacy-policy/
CSA STAR Registry — Dovetail	https://cloudsecurityalliance.org/star/registry/dovetail-research-pty-ltd

VERSION HISTORY

Version	Date	Changes
1.0	Mar 12, 2026	Initial vendor risk assessment for Dovetail Research Pty Ltd — Dovetail product. Net new vendor review.

A DOCUMENT REGISTER

Every document reviewed in this assessment is assigned a short reference code used for inline citations throughout the report. The evidence class indicates the source’s evidentiary weight: **auditor-attested** evidence has been independently verified by a third-party auditor; **vendor-self-attested** evidence is authored by the vendor and has not been independently verified.

Code	Document Title	Date	Evidence Class
SOC-01	SOC 2 Type II Report – Security, Confidentiality, Availability, Privacy, and HIPAA Security Rule BARR Advisory, P.A.	August 15, 2025 (period: July 1, 2024 – June 30, 2025)	AUDITOR
PEN-01	Dovetail Web and API Penetration Testing Report v1.0	September 12, 2025 (testing: September 1–11, 2025)	AUDITOR

Code	Document Title	Date	Evidence Class
	Razilio (Rowan Venables / CJ Infante)		
CSA-01	CSA Consensus Assessments Initiative Questionnaire v4.0.2 Dovetail Research Pty Ltd (self-attested)	2025	VENDOR
POL-01	Access Control Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.4 2025-01-10	VENDOR
POL-02	Anti-bribery and Anti-corruption Policy Channing White (Legal Counsel)	2025-01-16 (reviewed); v1.2 2025-01-16	VENDOR
POL-03	Asset Management Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.5 2025-03-26	VENDOR
GOV-01	Business Continuity and Disaster Recovery Plan Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.4 2025-02-25	VENDOR
POL-04	Cryptography Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.6 2025-04-21	VENDOR
POL-05	Data Management Policy Nathan Miller	2025-10-30 (reviewed); v1.2 2024-06-21	VENDOR

Code	Document Title	Date	Evidence Class
	(Head of Security and Compliance)		
POL-06	HIPAA Compliance Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.3 2025-04-01	VENDOR
POL-07	Human Resource Security Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.3 2024-07-09	VENDOR
POL-08	Information Security Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.8 2025-10-30	VENDOR
GOV-02	Information Security Roles and Responsibilities Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.4 2025-10-30	VENDOR
POL-09	Operations Security Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.4 2025-01-08	VENDOR
POL-10	Physical Security Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.5 2025-01-14	VENDOR
POL-11	Responsible Disclosure Policy Dovetail	Undated (current version at trust.dovetail.com)	VENDOR
POL-12	Risk Management Policy	2025-10-30 (reviewed); v1.5 2025-08-21	VENDOR

Code	Document Title	Date	Evidence Class
	Nathan Miller (Head of Security and Compliance)		
POL-13	Secure Development Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.4 2025-10-30	VENDOR
GOV-03	Security Incident Response Plan Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.9 2025-08-19	VENDOR
GOV-04	Security Hardening Guidelines Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.5 2025-01-08	VENDOR
POL-14	Third-Party Management Policy Nathan Miller (Head of Security and Compliance)	2025-10-30 (reviewed); v1.2 2025-04-16	VENDOR
GOV-08	SOC 3 Report – Security, Confidentiality, Availability, and Privacy BARR Advisory / Dovetail Research Pty. Ltd.	July 1, 2024 – June 30, 2025 (report dated Aug 15, 2025)	AUDITOR
GOV-07	ISO/IEC 42001:2023 Certificate of Registration BARR Certifications LLC	Issued June 6, 2025; Expires June 5, 2028	AUDITOR
GOV-06	Data Processing	Not explicitly dated (references Aug 2024 full DPA)	VENDOR

Code	Document Title	Date	Evidence Class
	Agreement – Web/Landing Page Summary Dovetail Research Pty. Ltd.		
GOV-05	Data Processing Agreement (Full) Dovetail Research Pty. Ltd.	Last updated August 8, 2024	VENDOR
ARC-01	Dovetail System Architecture / Data Flow Diagram Dovetail Research Pty. Ltd.	Downloaded March 9, 2026	VENDOR
GOV-09	Certificate of Insurance – Information Technology and Cyber Insurance Marsh Pty Ltd (broker); Chubb Insurance Australia Limited / Berkshire Hathaway Specialty Insurance (insurers)	Issued October 9, 2025; Policy period Sept 30, 2025 – Sept 30, 2026	VENDOR
CUS-01	Vendor Risk Review – Arcade Software, Inc. Claude Opus 4.5 (under human supervision)	December 31, 2025	CUSTOMER